



---

FACHARBEIT

# Backups, die niemand mitlesen kann

Daten verschlüsseln mit VeraCrypt und restic

---

Herausgeber: **FINLAI designs**

Linz, Oesterreich · [financial-analytics.eu](https://financial-analytics.eu)

Stand: 2026-06-26

*Entwickelt in Linz, Oesterreich*

**Herausgeber:** FINLAI designs · Linz, Oesterreich · financial-analytics.eu **Format:** Uebergreifende, erklärende, an wissenschaftliche Texte angelehnte (vorwissenschaftliche) Arbeit. Jeder Fachbegriff wird bei Erstnennung erläutert; jedes Kapitel beginnt mit einem Einstieg.

**Zielgruppe:** Geschäftsführung und IT-Verantwortliche in kleinen und mittleren Unternehmen (KMU) sowie technische Umsetzer — verständlich ohne tiefes Vorwissen. **Gegenstand:** Die praktische Vertiefung *einer* Backup-Frage — der Verschlüsselung. Wie wird eine Datensicherung so geschützt, dass weder ein gestohlener Datenträger noch ein fremder Speicheranbieter die Daten lesen kann? Beschrieben werden zwei sich ergänzende Schutzschichten und ihre Umsetzung mit zwei quelloffenen Werkzeugen. **Hinweis zur Tool-**

**Nennung:** Diese Arbeit nennt konkrete Werkzeuge (VeraCrypt, restic, Backrest). Diese Nennungen sind eine **redaktionelle Auswahl** (Stand Juni 2026), keine Empfehlung im Sinne einer Behörde und kein Vollständigkeitsanspruch. Versionsnummern werden bewusst nicht als „neueste“ eingefroren — Versionen und Sicherheitslage ändern sich. Vor dem Einsatz die aktuelle Version prüfen und Software ausschließlich aus der Originalquelle beziehen.

---

## Kurzfassung

---

Eine Datensicherung hält im Ernstfall nur, wenn sie zwei Dinge zugleich leistet: Sie muss *verfügbar* sein (eine Kopie überlebt den Schaden) und sie muss *vertraulich* sein (wer die Kopie in die Hände bekommt, kann sie nicht lesen). Diese Arbeit behandelt den zweiten Punkt und zeigt, dass dafür zwei verschiedene Verschlüsselungs-Schichten zusammenwirken: die **Verschlüsselung des Datenträgers im Ruhezustand** (eine externe Platte sieht von außen aus wie eine leere, unformatierte Platte) und die **clientseitige, zero-knowledge Verschlüsselung der Sicherung selbst** (die Daten werden auf dem eigenen Rechner verschlüsselt, *bevor* sie irgendwohin geschrieben oder hochgeladen werden — ein fremder Server sieht nur unlesbares Chiffre). Als konkrete, quelloffene Werkzeuge dienen **VeraCrypt** (Datenträger-Verschlüsselung) und **restic** (verschlüsselndes Backup-Programm), für Einsteiger ergänzt um die Oberfläche **Backrest**. Die Arbeit erklärt beide Schichten niederschwellig, beschreibt Bezug und Installation beider Werkzeuge inklusive der Prüfung der Originaldateien, anonymisiert die nötigen Quell- und Zielpfade so, dass jeder Leser den passenden Pfad bei sich selbst findet, und ordnet das Ganze in die maßgeblichen Rahmenwerke ein (NIS2 verlangt ausdrücklich den Einsatz von Kryptographie; die DSGVO nennt Verschlüsselung als Schutzmaßnahme; das BSI führt AES-256 als geeignetes Verfahren). Das Leitprinzip lautet: Eine Verschlüsselung schützt nur, solange der **Schlüssel** überlebt — und sie ersetzt keine Sicherungsstrategie, sondern härtet sie.

---

## 1. Einleitung — warum Verschlüsselung zum Backup gehört

---

**Einstieg:** Dieses Kapitel ordnet ein, warum eine Sicherung nicht nur *vorhanden* und *wiederherstellbar*, sondern auch *vertraulich* sein muss — und welche drei Alltagssituationen das erzwingen.

Wer ueber Datensicherung nachdenkt, denkt zuerst an Verfuegbarkeit: Ist im Schadensfall eine Kopie da? Das ist richtig, aber unvollstaendig. Eine Sicherung buendelt naturgemaef das Wertvollste eines Betriebs an einem Ort — auf einer externen Platte, auf einem Server, in einem Cloud-Speicher. Genau diese Buendelung macht sie zum lohnenden Ziel. Drei Situationen zeigen, warum die Sicherung verschluesselt sein muss:

- **Diebstahl und Verlust.** Eine externe Backup-Platte ist klein, mobil und liegt oft aufer Haus — genau dort, wo sie verloren gehen oder gestohlen werden kann. Ist sie unverschluesselt, liest der Finder Buchhaltung, Vertraege und Kundendaten im Klartext.
- **Fremde Speicherorte.** Die „eine Kopie aufer Haus“ landet haeufig bei einem Anbieter (Server, NAS, Cloud). Ohne clientseitige Verschluesselung vertraut man diesem Anbieter — und jedem, der ihn kompromittiert — die eigenen Daten an.
- **Meldepflicht.** Geraet ein unverschluesselter Datentraeger mit personenbezogenen Daten in falsche Haende, ist das in aller Regel eine meldepflichtige Datenpanne. War der Datentraeger hingegen stark verschluesselt, sind die Daten fuer Unbefugte „unzugaenglich“ — was die Pflichten deutlich entschaerfen kann (Kapitel 8).

Der teuerste Irrtum an dieser Stelle ist die Annahme, Verschluesselung sei eine Sache fuer „die mit Geheimnissen“. Tatsaechlich ist sie die guenstigste Versicherung gegen einen alltaeglichen Vorfall: den verlorenen Laptop, die verlegte Platte, den gehackten Speicher-Account. Diese Arbeit setzt voraus, dass eine Sicherungsstrategie nach der 3-2-1-1-0-Regel bereits existiert oder geplant ist (Kapitel 8 fasst sie kurz), und vertieft die eine Frage: Wie wird diese Sicherung so verschluesselt, dass sie auch in fremden Haenden schweigt?

---

## 2. Grundbegriffe (Glossar zum Einstieg)

---

**Einstieg:** Diese Begriffe tauchen im Rest der Arbeit auf. Wer sie kennt, kann das Kapitel ueberspringen und spaeter nachschlagen.

- **Backup / Datensicherung:** Eine zusaetzliche, versionierte Kopie wichtiger Daten an einem anderen Ort, aus der sich ein frueherer Zustand wiederherstellen laesst.
- **Restore / Wiederherstellung:** Das Zurueckspielen gesicherter Daten. Der Restore ist der eigentliche Zweck eines Backups; alles davor ist Vorbereitung.
- **Verschluesselung „at rest“ (im Ruhezustand):** Der gesamte Datentraeger (oder ein Container darauf) ist verschluesselt, solange er nicht eingebunden ist. Von auen wirkt er wie eine leere, rohe Platte.
- **Clientseitige Verschluesselung:** Die Daten werden auf dem eigenen Rechner (dem „Client“) verschluesselt, *bevor* sie geschrieben oder uebertragen werden.
- **Zero-Knowledge:** Eigenschaft eines Dienstes, der die abgelegten Daten nicht im Klartext kennt. Der Schluessel bleibt beim Nutzer; der Anbieter sieht nur Chiffprat.
- **Chiffprat / Klartext:** Klartext sind die lesbaren Originaldaten; Chiffprat ist ihr verschluesseltes, ohne Schluessel unlesbares Abbild.
- **AES-256:** Ein weltweit etablierter, symmetrischer Verschluesselungs-Algorithmus mit 256 Bit Schluessellaenge; gilt nach heutigem Stand als sicher und wird vom BSI als geeignet gefuehrt.

- **Container / Volume:** Eine verschluesselte Datei oder Partition, die nach dem Einbinden wie ein normales Laufwerk benutzbar ist.
- **Mounten / Einbinden:** Ein verschluesselltes Volume als Laufwerk verfuegbar machen (mit Passwort). **Dismount / Aushaengen:** wieder schließen — der Inhalt ist danach erneut verschluesselt.
- **Repository (Repo):** Bei restic der verschluesselte, deduplizierte Speicher-Container, in dem alle Sicherungen liegen.
- **Snapshot:** Ein vollstaendiger Stand der gesicherten Daten zu einem Zeitpunkt; bei restic dank Deduplizierung „billig“ (siehe naechster Punkt).
- **Inkrementell / Deduplizierung:** Nach dem ersten Lauf werden nur geaenderte Datenbloেকে gespeichert; identische Bloেকে nur einmal. Das spart drastisch Platz.
- **Diceware:** Ein Passwort aus mehreren zufaelligen Woertern — leicht abzuschreiben, aber durch seine Laenge sehr stark.
- **VSS (Volume Shadow Copy Service):** Ein Windows-Dienst, der einen eingefrorenen Moment-Abzug erstellt, sodass auch geoeffnete Dateien konsistent gesichert werden.
- **3-2-1-1-0-Regel:** Drei Kopien, zwei Medien, eine außer Haus, eine offline/unveraenderbar, null Fehler beim getesteten Restore.

---

### 3. Zwei Schichten: Verschlüsselung „at rest“ und clientseitig

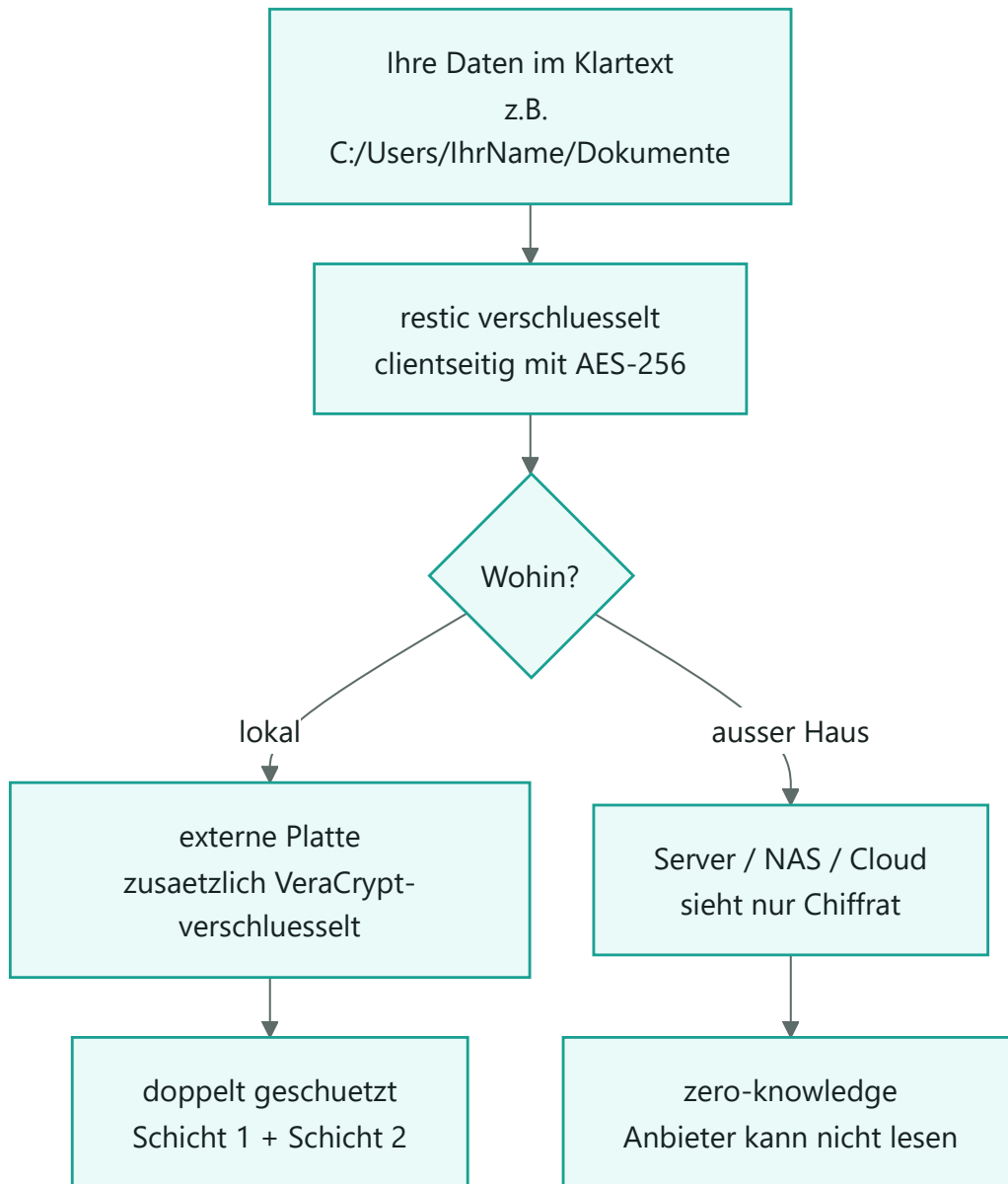
---

**Einstieg:** Dieses Kapitel erklart, warum eine durchdachte Sicherung *zwei* Verschlüsselungs-Schichten kombiniert — und was jede einzelne leistet, die die andere nicht kann.

Verschlüsselung ist nicht gleich Verschlüsselung. Fuer ein verschluesseltes Backup wirken zwei Schichten zusammen, die an verschiedenen Punkten ansetzen:

**Schicht 1 — der Datentraeger (at rest).** Eine externe Platte wird komplett verschluesselt. Solange sie nicht mit dem richtigen Passwort eingebunden ist, sieht das Betriebssystem nur eine rohe, scheinbar leere Platte — man erkennt nicht einmal, *dass* dort ueberhaupt eine Sicherung liegt. Das schuetzt gegen den physischen Fall: Die Platte wird gestohlen, verloren oder entsorgt. Werkzeug in dieser Arbeit: **VeraCrypt**.

**Schicht 2 — die Sicherung selbst (clientseitig, zero-knowledge).** Das Backup-Programm verschluesselt jeden Datenblock bereits auf dem eigenen Rechner, *bevor* er irgendwohin geschrieben wird. Das schuetzt unabhaengig vom Speicherort: Ob die Daten auf der lokalen Platte, auf einem fremden Server oder in der Cloud landen — ueberall liegt nur Chiffre. Selbst wer den Zielspeicher vollstaendig kontrolliert, kann nichts lesen. Werkzeug in dieser Arbeit: **restic**.



- Die clientseitige Schicht (restic) ist die wichtigere: Sie wirkt an *jedem* Ziel, auch in der Cloud, und ist die Voraussetzung dafür, eine Kopie überhaupt aus der Hand zu geben.
- Die Datenträger-Schicht (VeraCrypt) ist die sinnvolle Ergänzung für die lokale Platte: Sie verbirgt zusätzlich, dass dort eine Sicherung liegt, und schützt auch alles, was sonst noch manuell auf der Platte landet.
- Beide zusammen ergeben „Belt and Suspenders“ — Gürtel und Hosenträger. Fällt eine Schicht (etwa durch einen künftigen Implementierungsfehler), trägt die andere noch.

Wichtig ist die ehrliche Einordnung: Wer es einfacher mag, kann die externe Platte auch *nur* mit restic nutzen (Schicht 2 allein genügt für die Vertraulichkeit). VeraCrypt ist eine bewusste Zusatzhärtung, kein Muss. Diese Arbeit beschreibt den vollständigen, zweischichtigen Weg und markiert, wo man vereinfachen darf.

## 4. Werkzeug 1 — VeraCrypt: den Datentraeger verschluesseln

---

**Einstieg:** Dieses Kapitel beschreibt, woher VeraCrypt kommt, wie man die heruntergeladene Datei auf Echtheit prueft, und wie eine externe Platte verschluesselt und danach benutzt wird.

**Was es ist.** VeraCrypt ist ein quelloffenes Werkzeug zur Verschluesselung ganzer Datentraeger und Container. Es ist der gepflegte Nachfolger des eingestellten TrueCrypt und wird von Mounir Idrassi (Firma AM Crypto, vormals IDRIX) entwickelt.

**Bezug — nur aus der Originalquelle.** Verschluesselungs-Software ist ein beliebtes Ziel fuer gefaelschte Installer (untergeschobene Schadsoftware ueber Werbeanzeigen oder Tippfehler-Domains). Daher gilt ausnahmslos:

- Offizielle Projektseite: **veracrypt.io** (zugleich erreichbar ueber veracrypt.jp; die aelteren Adressen veracrypt.fr / veracrypt.eu leiten dorthin). Quelloffener Code: **github.com/veracrypt/VeraCrypt**.
- Fuer Windows die Installer-Datei aus dem Download-Bereich laden.

**Echtheit pruefen (wichtig, oft uebersprungen).** Das Projekt signiert jede Datei. Mindestens den Pruefsummen-Abgleich durchfuehren, idealerweise die PGP-Signatur:

- **Pruefsumme:** Auf der Downloadseite stehen SHA-256-/SHA-512-Summen. Die Summe der eigenen Datei (unter Windows z. B. mit `certutil -hashfile <Datei> SHA256`) muss exakt uebereinstimmen.
- **PGP-Signatur:** Der oeffentliche Schluessel hat den Fingerabdruck `5069A233D55A0EEB174A5FC3821ACD02680D16DE`. Stimmt der Fingerabdruck und prueft die Signatur fehlerfrei, stammt die Datei nachweislich vom Projekt.
- Unter Windows tragen die Installer zusaetzlich eine X.509-Signatur (sichtbar in den Dateieigenschaften).

**Eine externe Platte verschluesseln (einmalig).** In VeraCrypt ueber „Create Volume“ → „Encrypt a non-system partition/drive“ die externe Platte waehlen, als Verfahren AES und als Dateisystem exFAT (laeuft unter Windows und Linux). Achtung: Dieser Schritt **loescht** die Platte — also nur mit einer leeren oder bewusst neu aufzusetzenden Platte durchfuehren. Als Passwort dient eine starke Passphrase (Kapitel 6).

**Benutzen — einbinden und aushaengen.** Vor jeder Sicherung wird das Volume eingebunden, danach wieder ausgehaengt:

- **Einbinden:** Platte anstecken, in VeraCrypt einen **freien** Laufwerksbuchstaben waehlen — zum Beispiel `E:` — die Partition auswaehlen, „Mount“ klicken und das Passwort eingeben. Danach existiert `E:` im Explorer (in Git Bash als `/e/`).
- **Stolperstein:** Windows zeigt die rohe Platte oft unter einem *anderen* Buchstaben und meldet beim Anstecken „Datentraeger muss formatiert werden“. Das ist bei VeraCrypt normal — **niemals** auf Formatieren klicken, sondern in VeraCrypt einbinden.

- **Aushaengen:** Nach der Sicherung in VeraCrypt „Dismount“ und die Platte abstecken. Ab jetzt ist der Inhalt wieder vollstaendig verschluesselt und — abgesteckt — auch gegen Schadsoftware unerreichbar.

[Anonymisierungs-Hinweis: Der Laufwerksbuchstabe **E:** ist nur ein Beispiel. Entscheidend ist, dass es ein *freier* Buchstabe ist, den VeraCrypt beim Einbinden vergibt — nicht der, unter dem Windows die rohe Platte anzeigt.]

---

## 5. Werkzeug 2 — restic: die Sicherung clientseitig verschluesseln

---

**Einstieg:** Dieses Kapitel beschreibt Bezug und Installation von restic, das Anlegen eines verschluesselten Repositorys und den eigentlichen Sicherungslauf — und nennt fuer alle, die die Kommandozeile scheuen, eine grafische Oberflaeche.

**Was es ist.** restic ist ein quelloffenes Backup-Programm: ein einziges, eigenstaendiges Programm fuer Windows, Linux und macOS. Es sichert **inkrementell** (nur Aenderungen), **dedupliziert** (identische Bloecke nur einmal) und verschluesselt jeden Block **clientseitig mit AES-256**, bevor er das Geraet verlaesst. Der Zielspeicher — lokale Platte, SFTP-Server, S3, Cloud — sieht damit ausschliesslich Chiffprat.

**Bezug und Installation.** Ebenfalls nur aus der Originalquelle:

- Offizielle Seite: **restic.net**; Programmdateien und Pruefsummen auf **github.com/restic/restic** (Releases); Handbuch unter [restic.readthedocs.io](https://restic.readthedocs.io).
- Windows (einfachster Weg): in der Eingabeaufforderung oder PowerShell `winget install --id restic.restic`. Danach das Terminal neu oeffnen und mit `restic version` pruefen, dass eine Version erscheint.
- Linux: ueber die Paketverwaltung der Distribution oder das Binary von GitHub.

**Repository anlegen (einmalig).** Ein Repository ist der verschluesselte Speicher-Container. Beim Anlegen vergibt man das Repo-Passwort — den Schluessel zu *allen* darin liegenden Sicherungen. Fuer ein Repo auf der (zuvor mit VeraCrypt eingebundenen) externen Platte **E:** :

```
restic -r E:\Backup\repo init
```

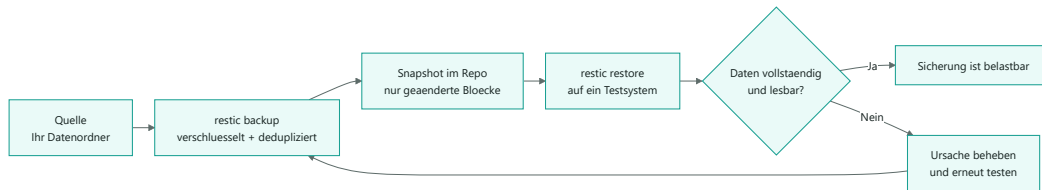
Fuer ein Repo außer Haus, auf einem eigenen Server oder NAS, wird nur das Ziel ausgetauscht:

```
restic -r sftp:IhrServer:/backups/repo init
```

**Sichern.** Der eigentliche Lauf benennt die zu sichernden Ordner; „Ihr wichtigster Datenordner“ ist nur ein Beispiel — hier den eigenen Pfad einsetzen. Unter Windows sorgt die Schattenkopie-Option dafuer, dass auch geoeffnete Dateien konsistent gesichert werden (nur Windows, nur mit

Administratorrechten):

```
restic -r E:\Backup\repo backup "C:\Users\IhrName\Dokumente" --use-fs-snapshot
```



- Der erste Lauf ist ein Voll-Backup; jeder weitere speichert nur Änderungen, ergibt aber dennoch jeweils einen vollständigen, einzeln wiederherstellbaren Snapshot.
- Mit einer Aufbewahrungsregel (`restic forget --keep-daily 7 --keep-weekly 4 --keep-monthly 12 --prune`) werden alte Snapshots automatisch ausgedünnt und Platz freigegeben.
- Der Restore-Pfeil zurück zum Anfang ist kein Schmuck: Erst der getestete Restore beweist, dass die Kette hält (Kapitel 7).

**Fuer alle, die die Kommandozeile scheuen — Backrest.** restic ist von Haus aus ein Kommandozeilen-Werkzeug; das ist fuer technisch weniger versierte Anwender eine echte Huerde. Die quelloffene Oberflaeche **Backrest** ([github.com/garethgeorge/backrest](https://github.com/garethgeorge/backrest)) legt eine Web-Bedienung darueber: Repositories anlegen, Zeitplaene setzen, Snapshots durchsuchen und einzelne Dateien per Klick zurueckholen. Sicherheits-Caveat: Backrest bindet seine Oberflaeche standardmaeßig nur an den eigenen Rechner (127.0.0.1) — das sollte so bleiben; die Oberflaeche gehoert **nicht** ungesichert ins offene Netz.

## 6. Der wichtigste Punkt: der Schluessel muss ueberleben

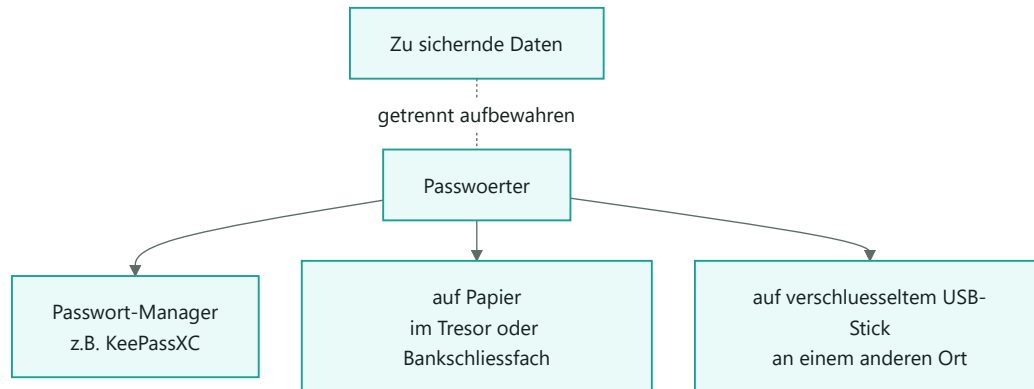
**Einstieg:** Dieses Kapitel behandelt den teuersten Anfängerfehler — denn die staerkste Verschluesselung ist wertlos, wenn der Schluessel mit den Daten untergeht.

Verschluesselung verschiebt das Problem: Aus „die Daten muessen ueberleben“ wird „die Daten  
und  
der Schluessel muessen ueberleben“. Liegt das einzige Exemplar eines Passworts auf genau dem Rechner, den man gerade sichert, und dieser Rechner geht verloren, dann ist die Sicherung unlesbarer Datenmuell — technisch perfekt verschluesselt und fuer immer zu.

In dem hier beschriebenen Aufbau gibt es zwei Passwoerter:

- das **VeraCrypt-Passwort** der externen Platte (Schicht 1),
- das **restic-Repo-Passwort** (Schicht 2).





- **Getrennt:** Der Schluessel darf nie ausschließlicly dort liegen, wo auch die Daten liegen. Sonst vernichtet *ein* Ereignis beides.
- **Redundant (dreifach):** Mindestens an drei unabhængigen Orten — Passwort-Manager, Papier im Tresor, getrennter USB-Stick. Geht eine Kopie verloren, bleiben zwei.
- **Stark, aber abschreibbar:** Eine Diceware-Passphrase aus mehreren zufælligen Woertern ist lang genug, um sicher zu sein, und laesst sich notfalls von Papier abtippen.

Merksatz: Man sichert nicht „die Daten“, sondern „die Daten und die Faehigkeit, sie wieder zu entschluesseln“. Diese Faehigkeit ist der Schluessel — und er gehoert in den Notfall-Umschlag (Kapitel 8).

---

## 7. Die ignorierte Null: der getestete Restore

---

**Einstieg:** Dieses Kapitel begruendet, warum erst der tatsaechlich durchgefuehrte Restore beweist, dass eine verschluesselte Sicherung im Ernstfall traegt.

Ein Sicherungslauf, der ohne Fehlermeldung durchlæuft, beweist nichts. Bei verschluesselten Backups kommt ein zusaetzlicher Stolperstein hinzu, den unverschluesselte nicht haben: Stimmt das Passwort nicht mehr, ist die Datei beschaedigt oder fehlt der Schluessel, scheitert nicht nur der Zugriff auf einzelne Dateien — die

*gesamte*

Sicherung bleibt zu. Genau das faellt erst beim echten Wiederherstellen auf.

Der Test ist einfach und gehoert in einen festen Rhythmus (etwa monatlich oder quartalsweise, dazu nach jeder groeßeren Aenderung):

- **Wiederherstellen:** Mit `restic -r <Repo> restore latest --target <Testordner>` einen Snapshot in einen separaten Wegwerf-Ordner zurueckspielen.
- **Pruefen:** Stichprobenartig kontrollieren, ob die zurueckgespielten Dateien vollstaendig und lesbar sind. Bei besonders wichtigen Dateien lohnt der Vergleich der Pruefsummen von Original und Wiederherstellung.
- **Integritaet:** `restic check` prueft, ob die gespeicherten Bloecke unbeschaedigt sind; `restic check --read-data-subset=10%` liest zusaetzlich eine Stichprobe der Daten.

Drei Stufen, aber nur eine ist der Beweis: `restic snapshots` zeigt, dass gesichert wurde; `restic check` prueft die Bloecke; und der `restore` belegt als Einziges, dass Daten, Schluessel und Verfahren zusammenspielen. Wer den Restore nie geprobt hat, hat keine Sicherung, sondern eine Hoffnung.

## 8. Einordnung: 3-2-1-1-0 und was die Rahmenwerke fordern

**Einstieg:** Dieses Kapitel verortet die Verschluesselung in der bekannten Backup-Faustregel und belegt, dass Behoerden, Normen und Gesetz sie ausdruecklich verlangen.

Verschluesselung ist kein Ersatz fuer eine Sicherungsstrategie, sondern eine ihrer Eigenschaften. In der **3-2-1-1-0-Regel** (drei Kopien, zwei Medien, eine außer Haus, eine offline/unveraenderbar, null Fehler beim getesteten Restore) wirkt sie an mehreren Stellen: Sie macht die „eine Kopie außer Haus“ ueberhaupt erst vertretbar (clientseitig, zero-knowledge) und haertet die „eine offline-Kopie“ gegen Diebstahl (Datentraeger at rest). Der „0“ — dem getesteten Restore — gibt sie eine zusaetzliche Bedeutung: Auch der Schluessel muss den Test bestehen.

Die einschlaegigen Rahmenwerke behandeln Sicherung und Verschluesselung als zusammengehoeorig:

| Quelle                                                             | Was sie zu Sicherung und Verschluesselung sagt                                                                                                                                                                                                                                             |
|--------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>NIS2-Richtlinie (EU) 2022/2555, Art. 21 Abs. 2</b>              | Verlangt unter lit. c „Backup-Management und Wiederherstellung nach einem Notfall“ und unter lit. h ausdruecklich Konzepte und Verfahren „fuer den Einsatz von Kryptographie und gegebenenfalls Verschluesselung“.                                                                         |
| <b>DSGVO (EU) 2016/679, Art. 32</b>                                | Nennt „die Verschluesselung personenbezogener Daten“ als beispielhafte geeignete technische Maßnahme. Nach Art. 34 Abs. 3 lit. a kann die Benachrichtigung Betroffener entfallen, wenn die betroffenen Daten — etwa durch Verschluesselung — fuer Unbefugte unzugaeenglich gemacht wurden. |
| <b>BSI IT-Grundschutz, Baustein CON.3 „Datensicherungskonzept“</b> | Verlangt ein geregeltes Sicherungskonzept; extern/offline gehaltene Datentraeger bieten den hoechsten Schutz; Sicherungen sind regelmaeßig auf Funktionsfaehigkeit zu pruefen.                                                                                                             |
| <b>BSI, Technische Richtlinie TR-02102-1</b>                       | Fuehrt AES (u. a. mit 256 Bit Schluessellaenge) als empfohlenes, langfristig geeignetes Verschluesselungsverfahren.                                                                                                                                                                        |
| <b>NIST CSF 2.0</b>                                                | Behandelt getestete Sicherungen in der Schutz-Funktion und die gepruefte Wiederherstellung in der Funktion „Recover“.                                                                                                                                                                      |
| <b>CISA (#StopRansomware-Leitfaden)</b>                            | Empfiehl ausdruecklich offline gehaltene, <b>verschluesselte</b> Sicherungen und das regelmaeßige Pruefen von Verfuegbarkeit und Integritaet.                                                                                                                                              |

Fuer den **DACH-Raum** ist die Lage 2026 eindeutig: In Deutschland ist das NIS2-Umsetzungsgesetz (neues BSIG) seit Dezember 2025 in Kraft; in Oesterreich tritt das NISG 2026 zum 1. Oktober 2026 in Kraft. Kleinstunternehmen fallen meist nicht *direkt* unter NIS2 — der Druck kommt mittelbar ueber

die Lieferkette und ueber die DSGVO, die unabhaengig von der Unternehmensgroesse gilt.

**Was NoRisk hier tut — und was nicht.** NoRisk enthaelt bewusst **kein** Backup- und kein Verschluesselungs-Werkzeug; beides gehoert in spezialisierte, getrennt betriebene Software. Was NoRisk leistet, ist die *Diagnose*: Der System-Scanner liest (lesend) den Verschluesselungsstatus von Laufwerken und kann darauf hinweisen, wenn eine Sicherung fehlt oder veraltet ist — das **Was** fehlt. Das **Wie** — Werkzeug, Schluesselverwahrung, Restore-Test — steht in dieser Arbeit.

---

## 9. Grenzen & Offenes (ehrlich)

---

**Einstieg:** Eine seriöse Arbeit benennt, was sie nicht leistet und wo Aussagen mit der Zeit altern.

- **Keine Rechtsberatung.** Die Einordnung von NIS2, DSGVO und nationalem Recht ist allgemeine Orientierung, kein Ersatz fuer die Pruefung des Einzelfalls. Ob eine Datenpanne meldepflichtig ist, haengt von Umstaenden ab, die hier nicht abschließend beurteilt werden koennen.
- **Werkzeuge und Versionen aendern sich.** Bezugsquellen, Signaturen und Sicherheitslagen haben den Stand Juni 2026. VeraCrypt etwa war Anfang 2026 zeitweise von einem Signatur-Problem betroffen (zurueckgezogene Microsoft-Treibersignatur, spaeter behoben). Vor dem Einsatz die aktuelle Lage pruefen und Software nur aus der Originalquelle beziehen.
- **Verschluesselung ist kein Backup.** Sie schuetzt die Vertraulichkeit, nicht die Verfuegbarkeit. Ohne mehrere Kopien an verschiedenen Orten (3-2-1-1-0) bleibt auch die best-verschluesselte Sicherung verwundbar — etwa gegen das gleichzeitige Verschluesseln durch Ransomware.
- **Der Mensch bleibt das Risiko.** Der haeufigste Totalverlust entsteht nicht durch geknackte Verschluesselung, sondern durch verlorene Schluessel. Kapitel 6 ist deshalb kein Anhang, sondern der Kern.
- **Kein Tiefenthema.** Schluesselverwaltung im großen Stil, Hardware-Sicherheitsmodule, unternehmensweite Verschluesselungsrichtlinien oder die Verschluesselung ganzer Serverlandschaften sind hier nicht Gegenstand.

---

## 10. Fazit

---

**Einstieg:** Die Kernaussagen in verdichteter Form.

Ein Backup muss nicht nur ueberleben, es muss auch schweigen. Vertraulichkeit entsteht aus zwei zusammenwirkenden Schichten: der clientseitigen, zero-knowledge Verschluesselung der Sicherung selbst (sie wirkt an jedem Ziel, auch in fremder Hand) und der Verschluesselung des Datentraegers im Ruhezustand (sie schuetzt die lokale Platte gegen Diebstahl und Verlust). Mit den quelloffenen Werkzeugen restic und VeraCrypt — fuer Einsteiger ergaenzt um Backrest — laesst sich beides ohne Lizenzkosten umsetzen. Entscheidend ist am Ende nicht die Wahl des Werkzeugs, sondern eine

Disziplin, die zwei Fragen beantwortet: Liegt der Schlüssel getrennt von den Daten und dreifach offline? Und wann wurde die Wiederherstellung zuletzt tatsächlich getestet? Wer beide Fragen ruhig beantworten kann, hat aus einer Sicherung einen verlässlichen Schutz gemacht.

---

## 11. Quellen & weiterführende Dokumente

---

**Einstieg:** Die folgenden Quellen belegen die Aussagen dieser Arbeit. Stand der Abrufe: Juni 2026.

### Werkzeuge (Originalquellen)

- VeraCrypt: [veracrypt.io](https://veracrypt.io) (bzw. [veracrypt.jp](https://veracrypt.jp)) · [github.com/veracrypt/VeraCrypt](https://github.com/veracrypt/VeraCrypt) · Prüfung der Downloads ueber PGP-Signatur (Fingerabdruck 5069A233D55A0EEB174A5FC3821ACD02680D16DE), X.509 und SHA-256/512.
- restic: [restic.net](https://restic.net) · [github.com/restic/restic](https://github.com/restic/restic) · [restic.readthedocs.io](https://restic.readthedocs.io).
- Backrest (Oberflaeche fuer restic): [github.com/garethgeorge/backrest](https://github.com/garethgeorge/backrest).

### Rahmenwerke & Behoerden

- BSI — IT-Grundschutz-Kompendium, Baustein CON.3 „Datensicherungskonzept“: [bsi.bund.de](https://bsi.bund.de).
- BSI — Technische Richtlinie TR-02102-1 (Kryptographische Verfahren, Schlüssellaengen): [bsi.bund.de](https://bsi.bund.de).
- NIST — Cybersecurity Framework 2.0, Funktionen „Protect“ und „Recover“: [nist.gov](https://nist.gov).
- CISA — #StopRansomware-Leitfaden (offline/verschlüsselte Backups, Test von Verfüegbarkeit und Integritaet): [cisa.gov](https://cisa.gov).

### Recht (Primaertexte)

- EU — Richtlinie (EU) 2022/2555 (NIS2), Artikel 21 Abs. 2 lit. c und lit. h (CELEX 32022L2555): [eur-lex.europa.eu](https://eur-lex.europa.eu).
- EU — Verordnung (EU) 2016/679 (DSGVO), Artikel 32 und Artikel 34 (CELEX 32016R0679): [eur-lex.europa.eu](https://eur-lex.europa.eu).
- Deutschland — NIS2-Umsetzungsgesetz / BSIG (in Kraft seit Dezember 2025): [gesetze-im-internet.de](https://gesetze-im-internet.de).
- Oesterreich — NISG 2026 (in Kraft ab 1. Oktober 2026): [ris.bka.gv.at](https://ris.bka.gv.at).

### Verwandte FINLAI-Arbeiten

- „Backup, das im Ernstfall haelt — Die 3-2-1-1-0-Regel praktisch fuer kleine Unternehmen“ (die uebergeordnete Sicherungsstrategie, in die sich diese Arbeit einordnet).

---

**Impressum.** Herausgeber: FINLAI designs, Linz, Oesterreich · [financial-analytics.eu](https://financial-analytics.eu). Stand: 2026-06-26. Redaktioneller Erfahrungs- und Recherchebericht, keine Rechts- oder Sicherheitsberatung und keine Gewaehr. Werkzeuge und Versionen aendern sich — vor dem Einsatz die aktuelle

Version prüfen, Software ausschließlich aus der Originalquelle beziehen und vor Änderungen ein Backup anlegen.